Vulnerability Assessment Report

GRC103 Risk Assessment and Management Techniques

Student	Eunice Adediran
Registration number	C11-26-CGRCE-17 595
Assessment	Practical Lab Vulnerability Assessment
Assessment date	25 October 2026
Assessment platform	Kali Linux and Metasploitable 2 virtual machines in UTM
Authorized target	192.168.128.3

Academic laboratory use only

The target was an intentionally vulnerable virtual machine connected to an isolated host only network. No public, institutional or unauthorized systems were scanned.

Executive Summary

The assessment identified a critically exposed laboratory host with 30 open TCP ports, obsolete software, insecure remote access services, an exposed administrative interface and two web findings detected by Nuclei. The highest organizational risks are direct remote command access through TCP port 1524, PHP CGI argument injection identified as CVE 2012 1823, and cleartext or trust based remote administration services. These weaknesses could allow an unauthenticated attacker on the same reachable network to gain control of the server, access or alter data, interrupt services and use the host as a foothold for further attacks.

The overall risk rating is Critical for a production environment. Metasploitable 2 is intentionally vulnerable, so the result is expected in this laboratory; however, the same conditions on a business system would require immediate isolation and incident handling. Management should prioritize removal of direct shell exposure and unnecessary services, replacement of unsupported software, restriction of administrative and database interfaces, secure configuration baselines, network segmentation and continuous vulnerability management.

Assessment Scope

In scope	Metasploitable 2 at 192.168.128.3
Assessment source	Kali Linux at 192.168.128.4
Network boundary	192.168.128.0/24 host only virtual network
Tools	Nmap 7.99, Nikto 2.6.0 and Nuclei 3.8.0 with templates 10.5.1
Techniques	Connectivity validation, full TCP port discovery, service and OS detection, web server review and template based vulnerability scanning
Excluded activity	Exploitation, password attacks, persistence, destructive testing and scanning of any system other than 192.168.128.3

Assessment Method

The work followed four controlled stages.

Environment validation Both virtual machines were placed on the same isolated /24 network. ICMP testing confirmed that Kali could reach the assigned target with no packet loss.

Network enumeration Nmap scanned all 65,535 TCP ports using SYN discovery, service version detection and operating system detection. Results were saved in Nmap, XML and grepable formats and converted to HTML.

Web assessment Nikto reviewed the HTTP service on TCP port 80 for insecure files, methods, headers and known web server weaknesses.

Template based validation Nuclei used signed community templates against the HTTP endpoint. The first attempt was retained as evidence of missing templates; templates were then updated while Metasploitable was powered off, the lab was returned to host only networking, and the scan was repeated.

Technical Results

Network Discovery and Nmap Results

The target responded at 192.168.128.3. Nmap scanned all TCP ports and reported 30 open ports and 65,505 closed ports. Detected services included FTP, SSH, Telnet, SMTP, DNS, HTTP, RPC, NetBIOS and SMB, remote execution services, Java RMI, a root shell, NFS, MySQL, PostgreSQL, VNC, IRC, Apache JServ and Tomcat. The operating system fingerprint matched Linux 2.6.9 through 2.6.33.

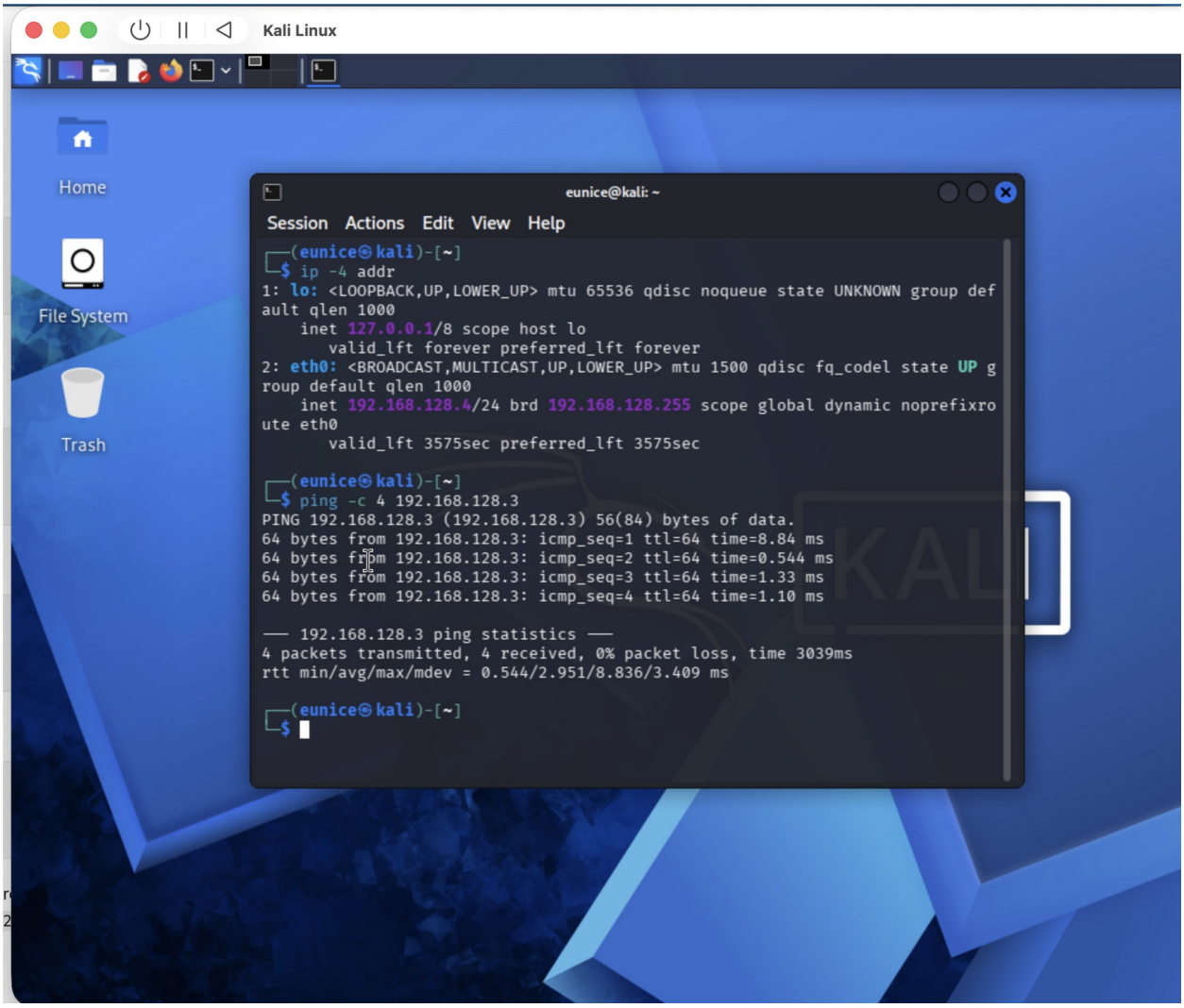


Figure 1 Kali address and successful connectivity test to the authorized target

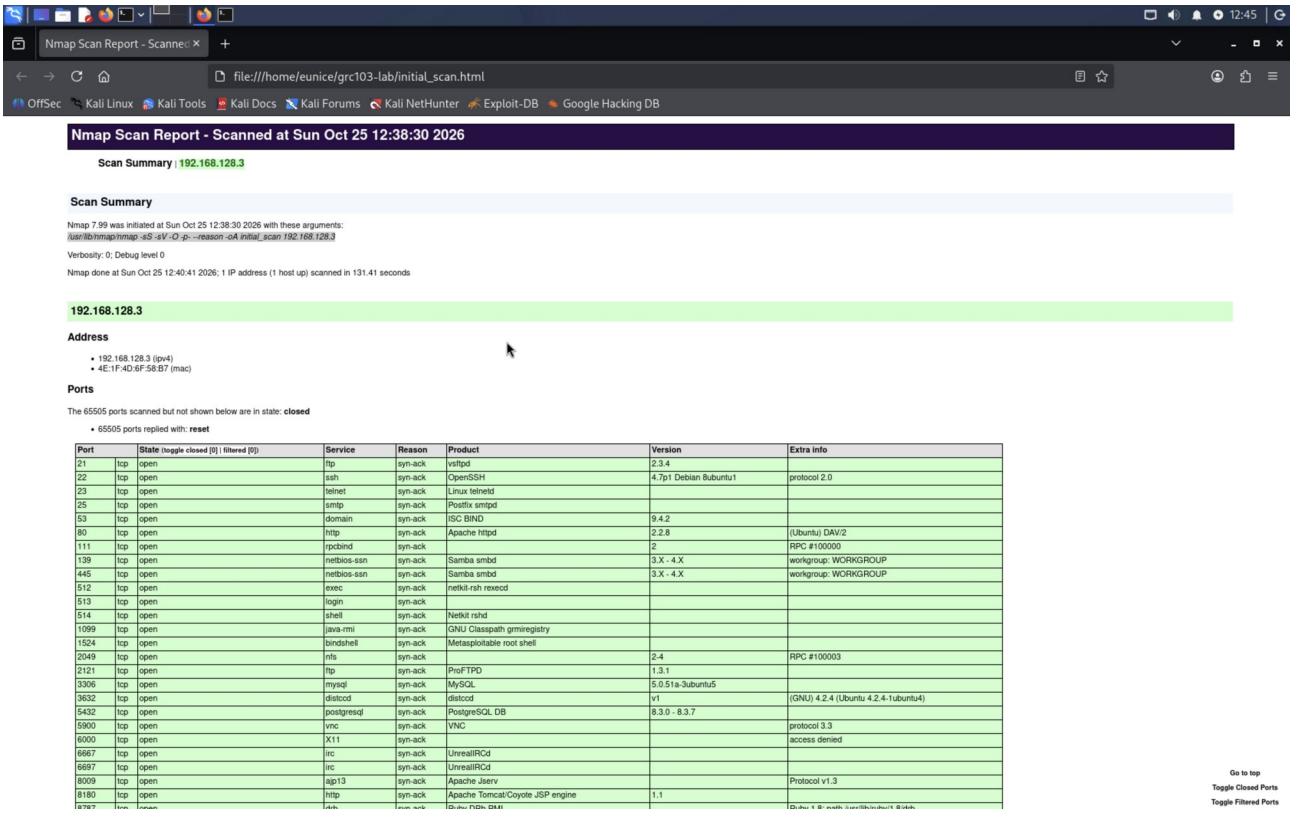


Figure 2 Generated Nmap HTML report showing the target and discovered services

Nikto Results

Nikto issued 8,242 requests and reported 30 items. The output identified obsolete Apache and PHP versions, the HTTP TRACE method, directory indexing, a publicly accessible phpinfo page, exposed phpMyAdmin documentation and change logs, default documentation files, potential information disclosure and missing defensive HTTP headers. These findings expand the attack surface and disclose information that can support targeted exploitation.



Figure 3 Nikto output showing obsolete components and web configuration weaknesses

Nuclei Results and Limitations

Nuclei loaded 11,200 signed templates and completed the isolated scan in approximately seven minutes. It produced two matches: CVE 2012 1823 at the PHP endpoint with tool severity High, and an informational match for the exposed phpMyAdmin panel. The run also reported 13 template runtime errors. Two checks that depended on external services could not resolve internet hosts because the target network was intentionally isolated. Nuclei 3.8.0 also reported that the engine version was outdated. These limitations reduce scan coverage and should be considered when interpreting the absence of additional matches.



Figure 4 Nuclei findings and recorded scan limitations

Risk Assessment Method

Each risk uses a five point likelihood score and a five point impact score. The risk score is likelihood multiplied by impact. Scores from 20 to 25 are Critical, 12 to 19 are High, 6 to 11 are Medium and 1 to 5 are Low. Likelihood considers exposure, authentication requirements, attack complexity and evidence from the scans. Impact considers potential effects on confidentiality, integrity, availability, regulatory obligations and business operations. Ratings describe a comparable production system; the assessed host itself is an intentionally vulnerable training machine.

Critical 20 to 25	Immediate containment and executive visibility
High 12 to 19	Prompt remediation under formal tracking
Medium 6 to 11	Planned corrective action and verification
Low 1 to 5	Monitor or accept through the risk process

Risk Register Summary

ID	Finding	Likelihood	Impact	Rating
R1	Direct root shell exposed on TCP port 1524	5 Likely	5 Severe	25 Critical
R2	PHP CGI argument injection detected	4 Probable	5 Severe	20 Critical
R3	Potentially backdoored vsftpd 2.3.4 service	3 Possible	5 Severe	15 High
R4	Cleartext and trust based remote access services	5 Likely	4 Major	20 Critical
R5	Exposed database and administrative services	4 Probable	4 Major	16 High
R6	Unsupported Apache and PHP software	4 Probable	4 Major	16 High
R7	Information disclosure through browsable and diagnostic content	4 Probable	3 Moderate	12 High
R8	Weak HTTP hardening and TRACE enabled	3 Possible	3 Moderate	9 Medium
R9	Excessive externally reachable services	4 Probable	4 Major	16 High

Detailed Risk Register

R1 Direct root shell exposed on TCP port 1524

Observed evidence	Nmap identified TCP 1524 as open with the product label Metasploitable root shell.
Affected service	TCP 1524 bindshell
Likelihood	5 Likely
Impact	5 Severe
Risk rating	25 Critical
Rating basis	A reachable command shell can provide direct privileged access without a legitimate administrative control path. Compromise would permit arbitrary system changes and rapid loss of confidentiality, integrity and availability.
Business impact	Unauthorized control, data theft or destruction, service interruption, lateral movement and material incident response costs.
Applicable controls	Nmap evidence; NIST CSF 2.0 PR.AA and PR.PS; CIS Controls 4, 6 and 12.
Recommended treatment	Remove the bind shell and rebuild the host from a trusted image. Restrict administrative paths, enforce authenticated encrypted management, segment the service network and monitor for shell activity.

R2 PHP CGI argument injection detected

Observed evidence	Nuclei matched CVE 2012 1823 at an index.php endpoint and assigned High severity.
Affected service	HTTP TCP 80 and PHP CGI
Likelihood	4 Probable
Impact	5 Severe
Risk rating	20 Critical
Rating basis	The finding indicates a remotely reachable injection condition. Successful exploitation may alter PHP configuration directives and can lead to disclosure or arbitrary code execution, depending on deployment

	conditions. The organizational rating is Critical because the endpoint is exposed and the potential impact is complete host compromise.
Business impact	Remote compromise of the application or host, exposure of application data, unauthorized changes and service disruption.
Applicable controls	CVE 2012 1823; OWASP Top 10 2025 A05 Injection; NIST CSF 2.0 PR.PS; CIS Controls 7 and 16.
Recommended treatment	Replace the unsupported PHP stack, remove CGI exposure where unnecessary, apply vendor fixes, restrict web access during remediation and validate the fix with authenticated testing.

R3 Potentially backdoored vsftpd 2.3.4 service

Observed evidence	Nmap identified vsftpd 2.3.4 on TCP 21. NVD records CVE 2011 2523 for compromised builds distributed during a defined 2011 period, with a CVSS 3.1 base score of 9.8.
Affected service	FTP TCP 21 and vsftpd 2.3.4
Likelihood	3 Possible
Impact	5 Severe
Risk rating	15 High
Rating basis	Version identification alone does not prove that this instance is the compromised distribution, so the finding requires package provenance validation. If affected, the backdoor can open a remote shell and cause complete compromise.
Business impact	Unauthorized shell access, credential and data exposure, malicious modification and use of the server for further attacks.
Applicable controls	CVE 2011 2523; NVD; NIST CSF 2.0 ID.AM and PR.PS; CIS Controls 2 and 7.
Recommended treatment	Disable FTP, validate package provenance and integrity, replace the package and operating system with supported versions, and use SFTP or another approved encrypted transfer service.

R4 Cleartext and trust based remote access services

Observed evidence	Nmap found Telnet on TCP 23 and remote execution services on TCP 512, 513 and 514.
Affected service	Telnet, rexec, rlogin and rsh
Likelihood	5 Likely
Impact	4 Major
Risk rating	20 Critical
Rating basis	These legacy services transmit or rely on weakly protected authentication and trust relationships. Any party with network access may intercept credentials, impersonate trusted systems or obtain command access.
Business impact	Credential theft, unauthorized administration, account misuse, lateral movement and loss of auditability.
Applicable controls	NIST CSF 2.0 PR.AA and PR.DS; CIS Controls 4, 5, 6 and 12; OWASP Top 10 2025 A04 Cryptographic Failures.
Recommended treatment	Disable Telnet and r services. Use SSH with current cryptography, key based authentication, least privilege, administrative network restrictions and centralized logging.

R5 Exposed database and administrative services

Observed evidence	Nmap found MySQL on TCP 3306 and PostgreSQL on TCP 5432. Nuclei identified an accessible phpMyAdmin panel.
Affected service	MySQL, PostgreSQL and phpMyAdmin
Likelihood	4 Probable
Impact	4 Major
Risk rating	16 High
Rating basis	Network reachable data services and administrative interfaces create direct paths to sensitive data and privileged operations. Weak or default credentials would increase likelihood further, although authentication was not tested in this assessment.
Business impact	Unauthorized disclosure or alteration of records, privacy and regulatory exposure, fraud risk, operational interruption and loss of customer trust.

Applicable controls	NIST CSF 2.0 PR.AA and PR.DS; CIS Controls 3, 4, 5, 6 and 12; OWASP Top 10 2025 A01 and A02.
Recommended treatment	Restrict database access to approved application hosts, place administration behind a management network or VPN, enforce strong unique credentials and MFA where supported, remove public phpMyAdmin access and log privileged activity.

R6 Unsupported Apache and PHP software

Observed evidence	Nmap reported Apache HTTP Server 2.2.8. Nikto reported PHP 5.2.4 and identified both components as obsolete.
Affected service	Apache TCP 80 and PHP runtime
Likelihood	4 Probable
Impact	4 Major
Risk rating	16 High
Rating basis	Unsupported components no longer receive normal security maintenance and are associated with publicly documented weaknesses. The exposed web service gives attackers a practical discovery and exploitation path.
Business impact	Application compromise, data exposure, defacement, malware installation, service outage and prolonged recovery effort.
Applicable controls	OWASP Top 10 2025 A03 Software Supply Chain Failures; NIST CSF 2.0 ID.AM and PR.PS; CIS Controls 2 and 7.
Recommended treatment	Migrate to supported operating system, web server and PHP releases. Establish software inventory, vulnerability monitoring, patch service levels, tested upgrades and exception governance.

R7 Information disclosure through browsable and diagnostic content

Observed evidence	Nikto found directory indexing, phpinfo.php, browsable documentation and phpMyAdmin change log and README files.
Affected service	HTTP TCP 80 and exposed web paths
Likelihood	4 Probable

Impact	3 Moderate
Risk rating	12 High
Rating basis	The exposed content reveals versions, paths, modules and file structure that improve attacker reconnaissance. It may also expose files that were not intended for unauthenticated users.
Business impact	Faster targeted attacks, disclosure of internal configuration, exposure of sensitive files and increased probability of successful exploitation.
Applicable controls	OWASP Top 10 2025 A02 Security Misconfiguration; NIST CSF 2.0 PR.PS; CIS Controls 4 and 16.
Recommended treatment	Disable directory listing, remove diagnostic and sample content, restrict administrative documentation, configure least privilege on web directories and review deployments for unintended files.

R8 Weak HTTP hardening and TRACE enabled

Observed evidence	Nikto reported HTTP TRACE and missing Permissions Policy, Content Type Options, Strict Transport Security, Content Security Policy and Referrer Policy headers.
Affected service	HTTP TCP 80 and Apache configuration
Likelihood	3 Possible
Impact	3 Moderate
Risk rating	9 Medium
Rating basis	Missing headers reduce browser side protections, while TRACE can support cross site tracing in vulnerable client and proxy conditions. These controls are defense in depth and should not be treated as proof of direct compromise by themselves.
Business impact	Increased exposure to content injection, framing, MIME interpretation and information disclosure attacks, particularly when combined with application flaws.
Applicable controls	OWASP Top 10 2025 A02 Security Misconfiguration; NIST CSF 2.0 PR.PS; CIS Controls 4 and 16.
Recommended treatment	Disable TRACE, enforce HTTPS, configure appropriate security headers, test application compatibility and automate

	header validation in deployment pipelines.

R9 Excessive externally reachable services

Observed evidence	Nmap reported 30 open TCP ports, including NFS, SMB, VNC, IRC, Java RMI, RPC, databases and multiple web services.
Affected service	Host network attack surface
Likelihood	4 Probable
Impact	4 Major
Risk rating	16 High
Rating basis	Each unnecessary service adds software, configuration and authentication paths that require maintenance and monitoring. The service mix indicates weak role separation and substantially increases the chance of exploitable exposure.
Business impact	Broader compromise paths, increased patching burden, greater outage probability, lateral movement and difficulty demonstrating effective control.
Applicable controls	NIST CSF 2.0 ID.AM, PR.PS and DE.CM; CIS Controls 1, 2, 4, 7, 12 and 13; OWASP Top 10 2025 A02.
Recommended treatment	Define the business role of the server, allow only required services, enforce host and network firewall rules, segment databases and management services, monitor exposed ports and review exceptions regularly.

Prioritized Remediation Plan

Immediate actions within 24 hours

- Isolate the affected server from user and production networks and preserve evidence if the exposure was not authorized.
- Remove the TCP 1524 bind shell and disable Telnet, rexec, rlogin and rsh.
- Restrict database, phpMyAdmin, VNC, NFS, SMB, RPC and Java RMI access to explicitly approved hosts.
- Treat unexpected exposure of these services on a business system as a potential security incident and review logs and integrity.

Short term actions within 30 days

- Rebuild or migrate the host to a supported operating system and supported Apache, PHP, FTP and database packages.
- Apply a secure configuration baseline, remove sample and diagnostic content, disable directory listing and enforce encrypted administrative access.
- Validate CVE 2012 1823 remediation and the provenance of the vsftpd package, then conduct a focused rescan.
- Document an approved service inventory and firewall policy for the server role.

Ongoing governance actions

- Maintain hardware and software inventories with named owners and approved purposes.
- Run authenticated vulnerability assessments on a defined schedule and track remediation against risk based service levels.
- Review network exposure continuously and alert on unauthorized services or configuration changes.
- Report unresolved Critical and High risks through the enterprise risk process with owners, due dates and formally approved exceptions.

Compliance and Governance Interpretation

The evidence shows why technical discovery is necessary for GRC work. Asset and service inventories support NIST CSF 2.0 Asset Management outcomes and CIS Controls 1 and 2. The concentration of obsolete and unnecessary services indicates weaknesses in platform security, secure configuration and continuous vulnerability management. The exposed web components align with OWASP categories for security misconfiguration, software supply chain failures and injection. These mappings do not by themselves establish legal noncompliance; an organization would compare the findings with its contracts, regulatory obligations, risk appetite and approved architecture before reaching a compliance conclusion.

Assessment Limitations

- The assessment covered one intentionally vulnerable host and one HTTP endpoint. Results do not represent an enterprise environment.
- Testing was unauthenticated and did not review application source code, credentials, configuration files, logs or business data.
- No exploit was executed. Version based findings require validation before concluding that a production system is exploitable.
- Nuclei reported 13 template runtime errors, an outdated engine and failed external dependency checks because the laboratory was isolated.
- The scan is a point in time assessment dated 25 October 2026. Changes after the scan may alter exposure.

Conclusion

The laboratory demonstrated a complete vulnerability assessment workflow from asset reachability through management reporting. The target exposed numerous services and several conditions capable of supporting full compromise. A comparable production host should be isolated immediately, rebuilt on supported software and returned to service only after unnecessary ports are closed, administrative paths are restricted and validation testing confirms that Critical and High risks have been addressed. The retained Nmap, Nikto and Nuclei outputs provide traceable evidence for remediation and follow up review.

Evidence Inventory

Nmap native output	initial_scan.nmap
Nmap XML output	initial_scan.xml
Nmap grepable output	initial_scan.gnmap
Nmap HTML report	initial_scan.html
Nikto output	nikto_scan.txt
Nuclei initial limitation	nuclei_initial_attempt.txt
Nuclei completed findings	nuclei_scan.txt
Nuclei execution log	nuclei_run.log
Evidence archive	grc103-technical-evidence.tar.gz



Figure 5 Verified inventory of retained assessment evidence

References

[1] National Institute of Standards and Technology. NIST Cybersecurity Framework 2.0. 2024. https://doi.org/10.6028/NIST.CSWP.29

[2] National Vulnerability Database. CVE 2011 2523 Detail. https://nvd.nist.gov/vuln/detail/CVE-2011-2523

[3] National Vulnerability Database. CVE 2012 1823 Detail. https://nvd.nist.gov/vuln/detail/CVE-2012-1823

[4] Center for Internet Security. CIS Critical Security Controls v8.1. https://www.cisecurity.org/controls/cis-controls-list

[5] OWASP Foundation. OWASP Top 10 2025. https://top10.owasp.org/

[6] OWASP Foundation. A02 2025 Security Misconfiguration. https://top10.owasp.org/2025/A02_2025-Security_Misconfiguration/

[7] Rapid7. Metasploitable 2 documentation. https://docs.rapid7.com/metasploit/metasploitable-2/